

Exzibo Vercel Serverless Architecture Audit

Exzibo / shriqrdotcom/exzibo-mag

29 July 2026

1. Executive summary

Final recommendation

RECOMMENDED WITH CONDITIONS — retain the current 12 Vercel entryptoint functions, do not merge unrelated public API domains, and make shared-service and route-contract parity the primary consolidation program.

The current repository has **12 deployable top-level handlers** under `api/`:

`auth.js`, `auth-check.js`, `bookings.js`, `media.js`, `menu-content.js`, `mobile/bootstrap.js`, `notifications.js`, `orders.js`, `restaurants.js`, `settings.js`, `system.js`, and `team.js`.

This is already a compact domain-router architecture: many public routes and rewrites map to a smaller set of physical handlers. `vercel.json` rewrites do not create additional functions. Further cross-domain merging would reduce physical files but would combine incompatible boundaries: OAuth, uploads, customer ordering, restaurant administration, superadmin operations, and system health/DDL have different risk profiles.

The most important work is therefore **not function-count reduction**. It is:

1. preserve the 12-function boundary;
2. verify and enforce per-action authorization and tenant scope;
3. eliminate Vercel/Express/Vite policy and business-logic drift through shared services and contract tests;
4. isolate or retire dangerous system DDL and preview-only flows;
5. add a repeatable Vercel function-count/build check before any new API file is added.

High-impact findings

- **VERIFIED:** 12 top-level handler files are present. `api/_lib/*` files are utilities, not entryptoints.
- **VERIFIED:** the Vite production client build passes (`vite v8.1.3`, 1,898 modules transformed).
- **BLOCKED FROM VERIFICATION:** no `.vercel/output/functions` directory exists, the Vercel CLI is not installed, and no local generated Vercel function manifest was available. Therefore the physical count is repository-derived, not deployment-derived.
- **VERIFIED:** `vercel.json` maps many REST-looking URLs to the same handlers using `?action=`; it does not imply one function per route.
- **VERIFIED:** Better Auth, R2 media, order/booking operations, and Cloudflare realtime have materially different runtime or security needs and should remain isolated.
- **VERIFIED:** the current code has substantial shared-service work already completed: handlers import `vercelWrapper`, `authz`, `validation`, `domain services`, and `database helpers`.
- **VERIFIED:** parity risk remains: `server.js` and `vite.config.js` contain their own route middleware and an Express-only long-lived outbox processor; they are not equivalent to Vercel execution.
- **HIGH:** `api/mobile/bootstrap.js` does not use the common `vercelWrapper` in the current source and creates its own pg pool (max: 2); it should receive explicit contract/security review.
- **HIGH:** `server.js` starts a process-owned realtime outbox processor. That is appropriate only for the long-lived Express runtime, not for a

Vercel function. The shared service comments identify an external cron job as the future alternative.

- **HIGH:** `api/system.js` exposes liveness/readiness plus removed-action handling, while `server.js` still starts preview and outbox processes. System/operations must not be casually merged into ordinary CRUD.
- **MEDIUM:** npm test is currently blocked by its glob referencing missing `tests/**/*.test.js`; this is reported, not fixed, because the audit is analysis-only.
- **MEDIUM:** an older `docs/serverless-function-analysis.md` is not current evidence: it refers to `api/menu.js` and `api/content.js`, which are absent. This report uses current `api/` and `vercel.json`.

2. Evidence and audit limitations

Evidence inspected

- `api/` and `api/_lib/`
- `vercel.json`
- `package.json` and `pnpm-lock.yaml` metadata
- `server.js`
- `vite.config.js`
- `src/services/`, `src/db/`, `src/monitoring/`
- `exzibo-realtime/wrangler.jsonc` and Worker source inventory
- `tests/`, `api/_tests_`, `docs/`, and `runbooks/`
- current build and test commands

Safe checks performed

- pnpm install was already available and the dependency tree resolved.
- npm run build passed with Vite 8.1.3.
- npm test was run and failed before executing tests because Node could not resolve `tests/**/*.test.js`; no source was changed.
- No production data was queried, no migration was applied, no deployment was made, and no environment value was read or printed.

Limitations

- Vercel CLI is not installed and `.vercel/output/functions` is absent; exact deployed output size/runtime cannot be independently verified locally.
- The repository does not contain a Vercel plan declaration. The plan's current function limit and any account-level quota are **BLOCKED FROM VERIFICATION** from repository evidence. Do not state remaining plan headroom until the account/deployment configuration confirms it.
- Traffic volumes, production latency, deployed bundle sizes, and live error rates are unavailable. Traffic profiles below are reasoned classifications, not measured production telemetry.
- The analysis does not inspect production data or deployment logs.

3. Current generated function count

Verified repository count

Evidence	Result
Top-level api/*.js files	11
Nested api/mobile/*.js handler	1
Top-level default-exported handlers	11
Nested default-exported handler	1
Repository-derived physical handler count	12
api/_lib/*.js	utilities; not entrypoints
api/_tests_/system.test.js	test; not endpoint

The count is **not** the route count. vercel.json contains dozens of rewrites, but rewrites point to existing handlers. For example, menu category, item, about, restaurant media, and social routes point to api/menu-content.js, api/media.js, or api/restaurants.js rather than creating new physical functions.

Function-count verification status

- **VERIFIED:** 12 candidate function files exist in the repository.
- **REASONABLE INFERENCE:** Vercel will treat each default-exported API file as a function under the conventional Vercel Node API layout.
- **BLOCKED:** generated Vercel output count and account plan limit cannot be confirmed without Vercel CLI/output or deployment metadata.
- **VERIFIED:** nested api/mobile/bootstrap.js is an API handler and must be counted separately from api/auth-check.js; the rewrite /api/mobile/v1/bootstrap points to it.
- **VERIFIED:** _lib has no default handler entrypoints and is imported as shared code.

4. Current function inventory

All handlers are JavaScript Node-style handlers unless otherwise noted. No runtime override appears in the inspected vercel.json, so the exact deployed runtime selection is **INFERRED** from the Vercel Node API convention and package code, not independently verified from a deployment manifest.

api/auth.js — authentication boundary

- **Routes:** /api/auth/:path*, rewritten to /api/auth?_path=:path*.
- **Methods:** delegated to Better Auth through toNodeHandler; auth endpoints necessarily include sign-in, callback, session, and sign-out behavior.
- **Auth:** public endpoint by design; it creates/verifies sessions rather than requiring one first.
- **Services/imports:** better-auth/node, src/lib/auth.server.js.
- **Data/external:** Better Auth tables in PostgreSQL; Google OAuth configuration.
- **Environment:** Better Auth secret/base URL/trusted origins, Google client credentials, database URL, and configured allowlist as used by the auth configuration.
- **Work:** authentication, DB reads/writes, external OAuth; no uploads, analytics, background loop, or realtime.
- **Profile:** medium/high traffic; very high security sensitivity; short-to-medium cold start risk due to auth/database dependency.
- **Classification:** public authentication boundary; must remain isolated.

api/auth-check.js — session and role checks / realtime ticket

- **Routes:** /api/auth-check; /api/realtime/ticket rewrites to ?action=issueTicket.
- **Methods:** GET for type=superadmin|member; POST for action=issueTicket; OPTIONS.
- **Auth:** session required for checks and ticket issuance; email comes from validated session.

- **Authorization:** superadmin allowlist or restaurant membership; realtime ticket service handles signed ticket issuance.
- **Services/imports:** authz.js, CORS, security wrapper, validation, realtimeTicketService.js.
- **Data/external:** Better Auth session, restaurant membership DB, realtime Worker endpoint/secret as configured by service.
- **Work:** auth reads, membership reads, realtime support; no ordinary CRUD writes.
- **Profile:** high request sensitivity but low payload; latency-sensitive during route selection; must remain separate from write routers.

api/restaurants.js — restaurant and analytics router

- **Routes:** /api/neon/restaurants, /api/neon/restaurant/create, /api/neon/restaurant/by-slug/:slug, /api/neon/restaurant/by-uid/:uid, /api/neon/restaurant/:id, /api/restaurant/:id, /api/restaurant/update-profile, /api/analytics/:restaurantId, and direct /api/restaurants?action=....
- **Actions:** list, listDeleted, bySlug, byId, byUid, analytics, checkSlug, neonRestaurant, myIds, create, update, updateProfile, platformUpdate, softDelete, restore, permanentDelete.
- **Methods:** GET for reads; POST/PATCH for mutations depending on action.
- **Auth:** mixed by action; myIds uses session; analytics uses authorizeAnalyticsAccess; restaurant mutations use role checks; superadmin actions use superadmin policy.
- **Services/imports:** restaurant lookup, creation transaction, analytics service/timezone, slug validation, authz, Neon helpers.
- **Data/external:** restaurants and related records in PostgreSQL; analytics queries; Upstash client IP helper.
- **Work:** reads/writes, transactions through createRestaurantAtomic, analytics; no uploads or permanent worker.
- **Profile:** medium traffic, high tenant/security sensitivity, potentially heavy analytics cold start/query risk.
- **Classification:** mixed restaurant and platform administration; keep separate from orders/media/auth.

api/settings.js — global, user, and restaurant settings

- **Routes:** /api/settings?action=...; /api/neon/restaurant-settings/shadow-upsert maps to setRestaurantSettings.
- **Actions:** getGlobal, setGlobal, getUserSettings, saveUserSettings, getRestaurantSettings, setRestaurantSettings.
- **Methods:** GET reads, POST writes, OPTIONS.
- **Auth:** superadmin for global writes and protected global reads; session for user settings; restaurant role checks for restaurant settings.
- **Services/imports:** authz, validation/error helpers, Neon settings/global DB modules.
- **Data/external:** global_settings, user_settings, restaurant_settings in PostgreSQL.
- **Work:** reads/writes; no transactions/ uploads/background/realtime.
- **Profile:** low-to-medium traffic; medium/high security sensitivity because global and tenant settings coexist.
- **Classification:** mixed but bounded settings router; separate from auth and uploads; can remain separate from notifications until contracts are proven compatible.

api/team.js — restaurant membership

- **Routes:** /api/team-members/:restaurantId, /api/team-members/shadow-upsert, /api/team-members/shadow-delete; direct /api/team?action=....
- **Actions:** list (GET), create, update, shadowUpsert, delete, shadowDelete.
- **Methods:** GET and POST; OPTIONS.
- **Auth:** restaurant access for reads and mutations; team service applies owner/admin rules and server-resolved tenant scope.
- **Services/imports:** authz, canonical team-service.js, Neon restaurant members, validation/error helpers.
- **Data/external:** restaurant_members and user identity in PostgreSQL.

- **Work:** reads/writes and safety checks; no external service, upload, background, or realtime.
- **Profile:** low/medium traffic, very high tenant/security sensitivity; keep isolated from public customer flows.

api/menu-content.js — menu and restaurant content router

- **Routes:** menu category/item routes, /api/about/*, /api/restaurant/update-social, and direct/api/menu-content?action=....
- **Actions:** getCategories, getItems, getPublishedItems, upsertCategory, deleteCategory, createItem, updateItem, upsertItems, deleteItem, getAbout, saveAbout, updateSocial.
- **Methods:** GET for reads, POST for writes; OPTIONS.
- **Auth:** published/customer reads may be public; management reads/writes use restaurant role authorization; exact policy is action-specific.
- **Services/imports:** menu service, restaurant content service, authz, validation, CORS, rate-limit/client-IP helpers.
- **Data/external:** menu_categories, menu_items, restaurant_about, restaurants in PostgreSQL.
- **Work:** reads/writes, some validation/rate limiting; no R2 upload in this handler.
- **Profile:** high public-read traffic and medium admin-write traffic; medium security sensitivity; keep separate from media because binary upload risk differs.

api/media.js — R2 image uploads

- **Routes:** /api/menu/upload-image, /api/about/upload-image, /api/restaurant/upload-logo, /api/restaurant/upload-carousel, and direct?action=....
- **Actions:** upload menu/about/logo/carousel, deleteImage.
- **Methods:** POST for uploads; DELETE or POST for delete according to handler contract; OPTIONS.
- **Auth:** admin CORS and service-level claims state authenticated manager+ access, but this boundary must be tested per action.
- **Services/imports:** mediaService.js, CORS/security wrapper, image validation and R2 client transitively.
- **Data/external:** Cloudflare R2; no ordinary relational transaction.
- **Work:** base64/data URL parsing, magic-byte/dimension/size validation, upload/delete.
- **Profile:** lower frequency but large bodies and high latency/timeout/cold-start risk; high credential sensitivity.
- **Classification:** upload boundary; must remain isolated.

api/orders.js — public order creation and restaurant order operations

- **Routes:** /api/orders, /api/orders/:restaurantId, /api/orders/update-status, /api/orders/auto-cleanup.
- **Actions:** GET list, public POST create with no action, updateStatus, autoCleanup.
- **Methods:** GET, POST, OPTIONS; status updates are POST action routes.
- **Auth:** public customer creation; restaurant role for list/status; superadmin for cleanup.
- **Services/imports:** order creation/status services, Neon orders, authz, Upstash rate limits/locks, realtime event/outbox services, validation.
- **Data/external:** orders/order_items in PostgreSQL; Upstash; transactional outbox and Cloudflare realtime publishing path.
- **Work:** reads/writes, transactions, rate limiting/locks, realtime event enqueue/publish coordination.
- **Profile:** high traffic and high operational importance; medium/high cold-start and timeout risk; keep isolated from bookings.

api/bookings.js — public booking creation and staff booking operations

- **Routes:** /api/bookings, /api/bookings/:restaurantId, /api/bookings/:id/status.
- **Actions:** list, create, update status.
- **Methods:** GET, POST, PATCH, OPTIONS.
- **Auth:** public customer create; restaurant role for list/status; status service applies management policy.
- **Services/imports:** booking creation transaction, booking status service, Neon bookings, authz, Upstash rate limiting/locks, validation.
- **Data/external:** bookings in PostgreSQL; Upstash.
- **Work:** reads/writes, transaction on creation, lock/rate limit on writes.
- **Profile:** medium/high traffic, customer-facing and operationally sensitive; keep separate from orders to preserve independent lock, validation, and rollback behavior.

api/notifications.js — notifications, messages, SMS metadata, help desk

- **Routes:** /api/notifications?action=... and /api/restaurant-notifications rewrite.
- **Actions:** createHelp, getActiveNotification, confirmActiveNotification, create, list, mark-read, dismiss, sendMessage, getMessages, publishActiveNotification, insertNotificationHistory, getNotificationHistory, getLatestSms, upsertSms, getHelp, updateHelpStatus, deleteHelp, markAllHelpRead.
- **Methods:** GET/POST according to action; OPTIONS.
- **Auth:** mixed: public/help submission rate-limited; session or restaurant access for user/restaurant actions; superadmin for platform notification/help/SMS actions.
- **Services/imports:** notification service, authz, validation/error helpers, Upstash rate limiting.
- **Data/external:** notification-related PostgreSQL tables; SMS metadata tables; no evidence of sending an external SMS provider in this handler.
- **Work:** reads/writes, rate limiting, no long-running process.
- **Profile:** low/medium traffic, high policy sensitivity because public and superadmin actions share a file; keep action allowlist and per-action auth explicit.

api/system.js — operations and health boundary

- **Routes:** /api/system; rewrites for liveness/readiness and legacy system actions are present in current code/config.
- **Actions:** current source explicitly handles liveness, readiness, and rejected/removed actions; the current vercel.json also routes restaurant-db paths to this handler, so this mapping must be reconciled and verified before deployment.
- **Methods:** GET/POST/OPTIONS as configured by vercelWrapper.
- **Auth:** liveness public; readiness superadmin-gated in source; removed actions fail closed. Any DDL action must be superadmin-only and separately reviewed.
- **Services/imports:** monitoring readiness, health helper, CORS, validation, safe errors, authz/security wrapper.
- **Data/external:** readiness checks and PostgreSQL; possible legacy schema provisioning route mapping.
- **Work:** health checks and potentially DDL if the mapped action remains reachable; no permanent loop in the Vercel handler itself.
- **Profile:** low traffic but maximum operational/destructive sensitivity; remain isolated.

api/mobile/bootstrap.js — mobile session bootstrap

- **Routes:** /api/mobile/v1/bootstrap rewrite.
- **Methods:** GET only; OPTIONS behavior is handler-specific.
- **Auth:** Better Auth session; identity is derived from session, not caller input; only selected restaurant roles are exposed.
- **Services/imports:** authz session helper; directpg pool and SQL.
- **Data/external:** restaurant membership/user data in PostgreSQL.
- **Work:** DB reads; no writes, uploads, analytics, background, or realtime.
- **Profile:** low/medium traffic, high privacy sensitivity, latency-sensitive on mobile startup; keep separate until it uses the same security/response middleware contract.

5. Complete route-to-function map

Public route / rewrite family	Physical function	Access class
/api/auth/:path*	auth.js	public auth boundary
/api/auth-check, /api/realtime/ticket	auth-check.js	authenticated/session and realtime-ticket
/api/menu/categories/*, /api/menu/items/*, /api/about/*, /api/restaurant/update- social	menu-content.js	mixed public content + restaurant management
/api/menu/upload-image, /api/about/upload-image, /api/restaurant/upload- logo, /api/restaurant/upload- carousel	media.js	restaurant admin upload
/api/orders, /api/orders/:restaurantId, /api/orders/update-status, /api/orders/auto-cleanup	orders.js	mixed public customer + sta superadmin
/api/bookings, /api/bookings/:restaurantId, /api/bookings/:id/status	bookings.js	mixed public customer + sta
/api/neon/restaurants, /api/neon/restaurant/*, /api/restaurant/:id, /api/restaurant/update- profile, /api/analytics/:restaurantId	restaurants.js	mixed public lookup + tenan admin + superadmin
/api/neon/restaurant- settings/shadow-upsert, /api/settings	settings.js	user, tenant, and superadmin settings
/api/team-members/*	team.js	tenant membership
/api/restaurant- notifications, /api/notifications	notifications.js	mixed public/session/tenant/supera
/api/system and system rewrites	system.js	public liveness; privileged readiness/operations
/api/mobile/v1/bootstrap	mobile/bootstrap.js	authenticated mobile
/(.*)	index.html	SPA fallback, not a function

6. Authentication and authorization matrix

Domain/action family	Required policy evidenced in current source	Finding
Better Auth endpoints	no pre-existing session; Better Auth owns flow	VERIFIED appropriate isolation
Session/member checks	Better Auth session plus superadmin allowlist or membership	VERIFIED in auth-check.js/authz.js
Order list/status	restaurant role; cleanup superadmin	VERIFIED imports/calls in orders.js
Booking list/status	restaurant role; public creation	VERIFIED imports/calls in bookings.js
Menu/content management	management roles; public published/content reads may be action-specific	VERIFIED action checks in menu-content.js; contract tests required
Media	manager+ claim documented by handler/service comments; per-action runtime test required	HIGH verification gap
Team	restaurant access plus team service owner/admin rules	VERIFIED current imports and server-resolved scope
Settings	session, restaurant roles, or superadmin depending on action	VERIFIED action-specific guards
Notifications	public help submission, session/restaurant access, superadmin platform operations	VERIFIED mixed policy; high boundary complexity
Restaurant admin	action-specific session/role/superadmin/analytics checks	VERIFIED mixed policy; review all public lookup actions
Mobile bootstrap	session only; role projection excludes privileged roles	VERIFIED documented contract; middleware parity gap
System	public liveness, privileged readiness; destructive operations must be isolated	VERIFIED liveness/readiness DDL mapping requires confirmation

Security conclusion: the current code demonstrates materially stronger authorization than the stale analysis document claimed. That document should not be used to assert that menu, orders, bookings, team, media, or notifications are unauthenticated. However, mixed routers still require per-action tests because a file-level import of authz is not proof that every action invokes the correct policy.

7. Domain and traffic analysis

Domain	Traffic	Body/runtime	Isolation value
Auth	bursty, latency-sensitive	small JSON/cookies, OAuth redirects	very high
Auth-check/ticket	frequent small reads	low body, signed ticket	high
Restaurant/analytics	admin reads/writes; analytics heavier	JSON, DB query variance	high
Team	low/medium, sensitive writes	small JSON, transactional safety	high
Orders	customer bursts + staff writes	JSON, locks/outbox	very high
Bookings	customer bursts + staff writes	JSON, transactional create	high
Menu/content	public reads + admin writes	JSON; high read volume	medium/high
Media	low frequency, large bodies	base64/images, R2 calls	very high
Notifications	low/medium, mixed trust	JSON, mixed actions	high
Settings	low, mixed trust	small JSON	medium/high
Mobile	startup-sensitive reads	small JSON, session DB read	high privacy
System	low but critical	health and possible DDL	maximum
Realtime Worker	persistent WebSockets/DO	long-lived state	absolute

8. Runtime-parity and duplication findings

What is shared correctly

- Vercel handlers generally use `api/_lib/security-middleware.js`, `authz.js`, CORS helpers, validation helpers, and domain services.
- `orders.js` uses `orderCreationService.js` and `orderStatusService.js`.
- `bookings.js` uses `bookingCreationService.js` and `booking-status-service.js`.
- `team.js` uses canonical `team-service.js`.
- `menu-content.js` uses `menuService.js` and `restaurantContentService.js`.
- `restaurants.js` uses `restaurantCreationService.js` and `analytics service`.

Where parity risk remains

- `server.js` has direct Express routes for orders, bookings, team, menu/content-related operations, and starts a process-level outbox processor. It delegates some routes to Vercel-style handlers later in the file, so the runtime is hybrid rather than a single canonical adapter.
- `vite.config.js` registers development middleware for mobile bootstrap, orders, bookings, team, notifications, and other APIs. It also explicitly parses query behavior because Vite middleware does not populate `req.query` automatically (documented project memory).
- `server.js` contains an in-memory preview-login attempt map and

setInterval; this is acceptable only for a long-lived preview/Express process and is not a serverless authority.

- CORS and method handling are implemented through several helper styles (setPublicCors, setAdminCors, setCredentialedCors, setCors) and should be covered by contract tests across adapters.
- api/mobile/bootstrap.js is a direct pg handler without the common vercelWrapper visible in the current source.

Recommended parity rule

Domain services must own business decisions and return stable result contracts; Vercel, Express, and Vite should only adapt request/response objects. For each public route, run the same contract suite against all available adapters.

9. Serverless compatibility findings

Compatible patterns

- Pools are cached/reused in several modules (api/_lib/authz.js, api/mobile/bootstrap.js, src/db/pg-sql.js) rather than created per query.
- Transactional services use explicit database clients for creation flows (bookingCreationService.js, restaurantCreationService.js).
- Realtime events are modeled through a transactional outbox (src/services/realtimeOutboxProcessor.js comments and src/db/schema.ts).
- External health calls use timeout/abort support in api/_lib/health.js.
- No request-time DDL is documented in api/auth.js; Better Auth schema bootstrap is a separate concern and must remain bounded and idempotent if retained.

Serverless hazards

- server.js starts startOutboxProcessor(outboxPool) at process startup (server.js around lines 1088–1098). A Vercel request handler must never depend on this process-owned loop. Use a separately scheduled worker/cron/consumer for production draining.
- server.js uses setInterval for preview rate-map clearing. It must never be copied into a Vercel handler.
- The Worker is stateful by design (exzibo-realtime/wrangler.jsonc binds a Durable Object). It is not a Vercel function candidate.
- Direct pools in multiple entrypoints can multiply concurrent connections if many functions scale at once. Keep low pool caps, reuse pools, and measure Neon connection saturation.
- System DDL (CREATE/DROP SCHEMA ... CASCADE) is fundamentally unsuitable as an ordinary public action; require an explicit operational gate, audit, and separate rollout.

10. Bundle-size and cold-start findings

The npm run build output is the client bundle, not Vercel function bundles. It proves the frontend build but cannot prove serverless bundle size.

Observed server dependency risks from imports:

- media.js transitively includes R2/AWS-compatible SDK and image/data validation; it handles large bodies and should remain isolated.
- auth.js includes Better Auth and OAuth integration; it should not import business domains.
- orders.js includes DB, Upstash, idempotency/lock, and realtime/outbox-related dependencies; merging it with bookings or notifications increases cold-start and failure coupling.
- restaurants.js includes analytics and restaurant-management dependencies; analytics query complexity is a reason not to merge it into a generic CRUD catch-all.
- notifications.js has the broadest mixed action set and should not

absorb settings/system.

- mobile/bootstrap.js is comparatively small but should use shared middleware/contracts.

Required measurement after any architecture change: produce actual Vercel build output and per-function compressed/uncompressed sizes in Preview. Do not infer serverless bundle sizes from dist/.

11. Security-boundary findings

Must remain isolated

1. **Better Auth (auth.js)** from all business APIs: stable OAuth callback/path and cookie/session lifecycle.
2. **Auth-check/ticket** from business writes: route-gating and signed realtime tickets have a distinct contract.
3. **Media/R2** from JSON CRUD: large body, storage credentials, binary validation, and different timeout behavior.
4. **Orders** from bookings: separate operational locks, transactional behavior, public burst profiles, and realtime outbox coupling.
5. **System/operations** from ordinary CRUD: liveness/readiness and any DDL/destructive operation have different blast radius.
6. **Cloudflare Worker/Durable Object** from Vercel: persistent WebSockets and stateful rooms require the Worker runtime.

Potentially shareable only after proof

- Restaurants + team + analytics are related by tenant administration, but team membership has stronger identity/role mutation rules and analytics has heavier queries. Keep physical endpoints separate; share services and authz utilities.
- Settings + notifications are both lower traffic but have different global/tenant/public/superadmin boundaries. Do not merge merely for count reduction.
- Menu and content are already safely bounded in menu-content.js because they share content-management roles and DB/service patterns. Do not add media to that router.

Every mixed router must enforce: action allowlist, method validation, per-action authentication, per-action authorization, server-resolved tenant scope, strict validation, unknown-action rejection, safe errors, request IDs, and fail-closed defaults.

12. Architecture options comparison

Option	Count	Security isolation	Maintainability	Cold starts	D
A. Keep current 12	12	strong domain isolation	good if shared services stay canonical	bounded per domain	B, bi
B. Domain routers (broad merge)	likely 7-9, exact count not safely determinable without implementation	weaker; mixed trust boundaries	fewer files, broader routers	larger bundles and wider failure blast radius	re de
C. One catch-all	1	poor; must recreate all boundaries inside one router	poor; high coupling	worst broad cold start	re
D. Hybrid	likely 8-10, exact count implementation-dependent	potentially good	complex migration and rewrite risk	mixed	no ju by cl ev

The current architecture has already achieved most of the safe function-slot consolidation: each function is a domain router, not a CRUD endpoint. The evidence does not justify paying the security, rollback, and bundle costs of another cross-domain merge.

13. Recommended target architecture

Exact target

12 Vercel functions, with the current public route families retained and no cross-domain function merges.

Proposed physical endpoints:

1. api/auth.js — Better Auth only.
2. api/auth-check.js — session/member checks and realtime ticket issuance.
3. api/restaurants.js — restaurant lifecycle and analytics.
4. api/settings.js — global/user/restaurant settings.
5. api/team.js — tenant membership.
6. api/menu-content.js — menu and restaurant content.
7. api/media.js — R2 media only.
8. api/orders.js — order creation, reads, status, bounded cleanup action.
9. api/bookings.js — booking creation, reads, status.
10. api/notifications.js — notification/message/help actions with explicit policies.
11. api/system.js — health and tightly gated operations.
12. api/mobile/bootstrap.js — authenticated mobile bootstrap.

What changes in the target

- **No public route renaming is required.** Existing rewrites remain the compatibility layer.
- All domain business logic stays in `src/services/` and `src/db/`; handlers remain thin adapters.
- Express and Vite call the same domain services and route contracts, not independent SQL/business implementations.
- The outbox consumer runs as an external scheduled/long-lived consumer, never as a Vercel request-process assumption.
- System DDL and preview-only actions are either removed from production routing or protected behind an explicit, separately audited operational boundary.
- Mobile bootstrap is brought under the same method/error/request-ID/security contract, without merging it into auth-check.

14. Before-and-after function map

Current	Target
auth.js	keep auth.js
auth-check.js	keep auth-check.js
restaurants.js	keep restaurants.js
settings.js	keep settings.js
team.js	keep team.js
menu-content.js	keep menu-content.js
media.js	keep media.js
orders.js	keep orders.js
bookings.js	keep bookings.js
notifications.js	keep notifications.js
system.js	keep system.js, narrow/secure operations
mobile/bootstrap.js	keep mobile/bootstrap.js, align adapter contract
Vite/Express duplicate route logic	deduplicate behind shared services/contracts; not counted as Vercel functions
Cloudflare Worker/DO	remain independent deployment

Function headroom

- **Expected final count:** 12.
- **Expected unused headroom: BLOCKED FROM VERIFICATION** until the active Vercel plan limit is confirmed from account/deployment evidence. The repository proves neither a plan limit nor deployed function quota.
- Governance must fail CI/Preview if the count changes unexpectedly, rather than relying on an assumed plan limit.

15. Functions to merge, keep separate, and remove

Merge at the route level

None across current physical functions. The only safe cleanup candidate is the `update` versus `updateProfile` action alias in `restaurants.js`, but deprecate only after repository-wide caller search and a compatibility window.

Share code while keeping routes separate

- `auth/session` policy utilities across handlers;
- `menu/content` service code already used by `menu-content.js`;
- `order/booking` status contracts;
- `team` service and `tenant-scope` resolution;
- `validation`, `safe-error`, `request-ID`, `CORS`, and wrapper behavior;
- `preview-auth` core only if preview mode remains supported;
- `outbox claim/publish` services for the external consumer, not Vercel.

Remove or quarantine after verification

- obsolete `/api/migrate` caller/handler behavior, if confirmed no longer needed;
- stale `system restaurant-DB DDL` routes if the `row-based restaurants/restaurant_members` model is canonical;
- `restaurants.js` action alias only after caller and Preview verification.

16. Proposed route and rewrite

map

Retain existing compatibility mappings in `vercel.json` for the target architecture. The important invariant is one-to-one ownership by domain:

- `/api/auth/:path*` → `api/auth.js`.
- `/api/realtime/ticket` and `/api/auth-check` → `api/auth-check.js`.
- `/api/menu/*`, `/api/about/*`, and social content routes → `api/menu-content.js`.
- all image upload routes → `api/media.js`.
- all order routes → `api/orders.js`.
- all booking routes → `api/bookings.js`.
- all restaurant and analytics routes → `api/restaurants.js`.
- settings routes → `api/settings.js`.
- team-member routes → `api/team.js`.
- notification routes → `api/notifications.js`.
- system/health routes → `api/system.js`.
- mobile bootstrap → `api/mobile/bootstrap.js`.

Before implementation, verify the current `vercel.json` entries for system DDL and analytics against handler actions; a rewrite is not proof that a destination action still exists.

17. Future function-governance rules

Before adding an API file:

1. **Can the feature live inside an existing domain?** Add an action only if it shares the same tenant/security boundary, runtime, body-size profile, and operational owner.
2. **Does it cross trust boundaries?** Create/isolate a function for OAuth/auth, platform admin, customer-vs-staff flows, uploads, destructive operations, or internal operations.
3. **Does it require a different runtime or lifetime?** Use Cloudflare Worker/DO or an external consumer for WebSockets, durable state, and permanent/background processing.
4. **Does it need large bodies or binary processing?** Keep it separate from JSON routers.
5. **Is the action allowlisted and method-bound?** Unknown actions must fail closed; every action needs an explicit HTTP method and auth policy.
6. **Is tenant scope server-resolved?** Never trust a body restaurant ID as the final authorization scope.
7. **Is business logic shared?** Put it in `src/services//src/db/`; Vercel, Express, and Vite are adapters.
8. **Is parity tested?** Run route-contract tests against every supported runtime adapter.
9. **Is function headroom known?** Count api entrypoints and verify generated Vercel output in Preview; do not assume a plan limit.
10. **Can it roll back independently?** If not, the proposed merge is probably too broad.

18. Implementation pull-request roadmap

This is a roadmap only; no implementation was performed in this audit.

PR	Purpose	Main areas	Count effect	Risk/tests
1	Freeze current route inventory and ownership	vercel.json, API contract manifest, docs	0	low; route snapshot and rewrite tests
2	Add adapter-neutral request/response contract tests	api/_lib, api/_tests__, Vite/Express adapters	0	medium; methods: unknown actions, safe errors, IDs
3	Align mobile bootstrap with common security/error contract	api/mobile/bootstrap.js, shared middleware	0	medium-high; session, role projection, no-store, 401/405
4	Verify system routing and quarantine dangerous DDL/preview paths	api/system.js, vercel.json, ops docs	0	high; liveness/readiness: fail-closed, non-prod destructive tests
5	Remove runtime business duplication	server.js, vite.config.js, src/services/	0	medium-high; same contract suite across runtimes
6	Separate outbox consumer from request runtime	server.js, consumer scripts, Worker/cron operations	0	high; claim/lease, retry, shutdown, duplicate publish tests
7	Deprecate only proven dead aliases/calls	restaurant alias and any migrate call	0	medium; repository search, Preview smoke, rollback
8	Add generated-function governance check	CI/release scripts and deployment docs	0	low; frozen install Vercel Preview count and diff

19. Validation plan

After any implementation:

- frozen pnpm install --frozen-lockfile;
- build and static import checks;
- route inventory and rewrite tests;
- HTTP-method and OPTIONS tests;
- unknown-action rejection;
- auth/session and Google callback tests;
- superadmin, role, and tenant-isolation tests;
- CORS and trusted-origin tests;
- validation, safe-error, and request-ID tests;
- order creation/status/idempotency/lock/outbox tests;
- booking creation/status tests;
- membership owner/admin boundary tests;
- menu/content and full-upsert contract tests;
- R2 magic-byte/size/dimension/upload/delete tests;
- mobile bootstrap privacy and no-store tests;
- analytics authorization and timezone tests;
- liveness/readiness tests;
- realtime ticket and Worker publish tests;
- local/Preview Vercel build;
- generated function-count check;
- staging smoke tests for every rewrite;
- rollback test and route compatibility check.

The current repository's npm test command must first be made runnable or replaced with a valid test discovery command; until then, test completeness is not demonstrated.

20. Rollback plan

- Keep each consolidation/deduplication PR independently reversible.
- Do not delete an old route or rewrite until a Preview contract test and smoke test prove the replacement.
- For authorization changes, retain logs/request IDs and roll back the single domain adapter, not the whole API tree.
- For system DDL changes, require a database backup and an explicit restore rehearsal before production.
- For outbox changes, stop the new consumer, preserve leases/rows, and restart the known-good consumer; verify no event loss or duplicate side effects.
- If a Vercel Preview shows unexpected function growth, revert the endpoint change before investigating bundle size.

21. Risks and trade-offs

- Retaining 12 functions does not eliminate cost or cold starts; it preserves isolation at the price of repeated platform initialization and deployment metadata.
- Shared services reduce drift but can create a broad blast radius if a shared contract changes without domain tests.
- Keeping notifications/settings separate uses more slots than a broad router but prevents public, tenant, and platform-admin policies from silently mixing.
- Orders and bookings remain duplicate-shaped domains, but their transaction/lock/traffic behavior is sufficiently different that merging is not worth the risk.
- System DDL may be legacy and its route mapping may be stale; deleting it without a product/data decision could break an operational workflow, while retaining it without a gate could be dangerous.
- The account's Vercel plan limit and deployed function output remain unknown; the target count must be confirmed in Preview before release.

22. Architecture score out of 10

8.0/10 for the current target direction.

- Security isolation: 8.5 — strong domain separation and shared authz utilities, with action-level verification still required.
- Maintainability: 8.0 — domain routers and services are clear; Vite/Express duplication lowers the score.
- Testability: 6.5 — focused system tests exist, but the primary test command is currently blocked.
- Serverless compatibility: 8.0 — Vercel handlers are bounded; Express outbox lifetime must not be confused with Vercel.
- Performance: 7.5 — domain-sized bundles are preferable to a catch-all; actual function bundle measurements are pending.
- Operability: 7.5 — health/readiness and runbooks exist; generated function/plan verification is missing.

23. Final decision

RECOMMENDED WITH CONDITIONS

The best architecture for this repository is the current **12-function, domain-router architecture**, with strict preservation of these isolated boundaries: Better Auth, auth-check/realtime tickets, media/R2, orders, bookings, system/operations, mobile bootstrap, and the separate Cloudflare realtime Worker. No cross-domain handler consolidation is recommended. Consolidate shared implementation and runtime adapters instead, and keep public rewrites stable.

This is better than the current structure only insofar as it removes duplicated Vite/Express business logic, aligns mobile/system contracts, and adds generated-count/route-parity governance. It is better than one catch-all because it limits security, bundle, timeout, rollback, and tenant-isolation blast radius while keeping each function compact enough to test.

Recommended final function count: 12. Expected unused headroom is not stated because the active Vercel plan limit is not present in

repository evidence.

Single most important next action: add a read-only route-contract and generated-function verification step in CI/Preview, then use it to reconcile vercel.json system/analytics mappings and prove every deployed route before any consolidation or deletion.